SC4016 – Ransomware Leak Site Analysis (Jan–Sep 2026)

Oct 5, 2026 · @yew yi

Dataset and method

We analysed **422 victim posts** scraped from five data leak sites (DLS), filtered to 1 Jan – 30 Sep 2026.

Group	Victims (Jan–Sep)	Active window in data	Fields available
Play	167	2 Jan – 21 Sep	country, dates, views, publish status
Chaos	83 published (+43 pending)	snapshot 2 Oct (no post dates)	sector, country, leak size, views
Anubis	65	8 Jan – 22 Sep	industry, country, leak size, data types
SETTRA	64	22 Jun – 30 Sep	revenue, leak size, views
DireWolf	43	4 Jan – 8 Sep	industry, country, data types, row counts

To compare groups, we mapped every victim to one of 17 common industries. Play and SETTRA list no industry, so we classified those victims by company name and website. We inferred SETTRA countries from the domain's country code or the company's known HQ; 27 victims (6%) stay "Unknown". Data-type analysis (Q8) uses the 89 Anubis and DireWolf posts that describe what was stolen.

Caveats: a leak site only lists victims who **did not pay** (or have not yet), so this is a view of failed negotiations, not of all attacks. Leak sizes, revenues and view counts are the criminals' own claims.

Q1. Which countries are most targeted?

The United States, by far: 267 of 395 victims with a known country (68%). Canada (7%), the UK (6%) and Germany (3%) follow; every other country is under 2%. The pattern holds in every group: the US is the top country for all five, from 78% of Play's victims to 30% of DireWolf's.

Two in three victims are US organisations

Victims by country, top 11 of 38 countries, Jan–Sep 2026 (share of victims with a known country)



Combined Play, Chaos, Anubis, SETTRA, DireWolf leak-site data · 422 victims, 395 with a known country

The Anglosphere (US, Canada, UK, Australia, NZ) accounts for 82% of victims. DireWolf is the outlier, with a much wider spread across Asia and Latin America (Malaysia, India, Thailand, Brazil, Argentina, Guatemala).

Q2. Why are some countries targeted more than others?

Ransomware is a business: actors go where companies are rich, digitised, reachable and likely to pay. The US-heavy pattern follows from five factors.

1. **Ability to pay.** The US has the largest number of mid-sized private firms with real revenue and cyber-insurance cover. That is exactly the profile in our data: SETTRA's median victim has about $19M revenue.
2. **Attack surface.** Most victims are found by scanning for exposed VPNs, firewalls and remote-access tools (Play's 2026 entry points are Check Point, Cisco FMC and ScreenConnect bugs) or by buying infostealer logs. The more internet-facing English-language businesses a country has, the more hits a scan returns.
3. **Leverage from regulation.** US breach-notification laws, HIPAA and class-action lawyers make a public leak expensive. That pressure is what double extortion sells.
4. **Language and culture.** Russian-speaking ecosystems target English-speaking victims they can negotiate with. They traditionally avoid CIS countries; none appear in our 38 countries.
5. **Low risk of arrest.** Western victims are far from the actors' jurisdictions, with no extradition.

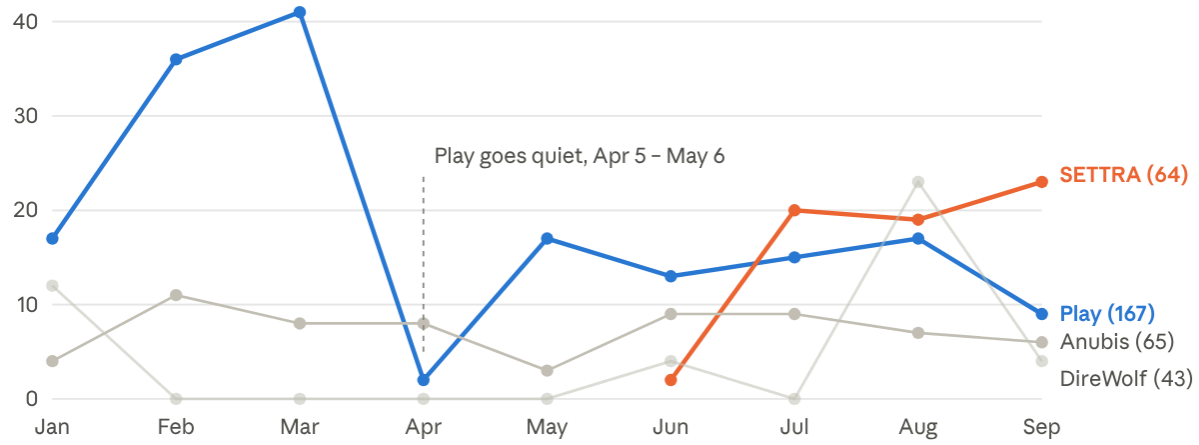
Our data is also biased: leak-site trackers and English-language reporting cover US victims best, and SETTRA hides many countries behind ".com" domains.

Q3. Which group is the most prolific or successful?

Play is the most prolific: 167 victims in nine months, 40% of everything we collected and more than double any other group. It posted every month, in batches of up to 9 victims a day, and kept a steady 4-day countdown from listing to leak.

Play led on volume for most of the year; newcomer SETTRA matched it from July

Victims posted per month, Jan–Sep 2026 (Chaos excluded: its posts carry no dates)



Play, SETTRA, Anubis, DireWolf leak sites · 338 dated victim posts, Jan–Sep 2026

"Successful" needs more than a count, so we scored each group on four measures.

Group	Victims	Victims per active month	Claimed data stolen	Signal of impact
Play	167	18.6 (9 months)	not listed	87% of posts "PUBLISHED FULL"; up to 43,000 views per post
SETTRA	64	19.2 (since 22 Jun)	19.2 TB (57 posts)	Doosan ($13B revenue), DyStar, Petra Diamonds; 77 victims in 23 countries by late Sep
Chaos	83 (+43 pending)	no dates	38.0 TB, avg 458 GB	Top post viewed 313,304 times; 41 countdowns still open on 2 Oct

Group	Victims	Victims per active month	Claimed data stolen	Signal of impact
Anubis	65	7.2	19.1 TB (48 posts)	Coca-Cola/Fairlife (Reuters), Winn-Dixie, AkzoNobel
DireWolf	43	bursty (12 in Jan, 23 in Aug)	row counts, e.g. ~1.28 billion rows from Cartrack	SaaS platforms holding many customers' data

Verdict: Play is the most prolific and consistent operator; Chaos is the most damaging per victim (largest leaks, most views). SETTRA is the one to watch: a new name in June that already matches Play's monthly pace and lands larger, richer victims. A caveat for all of them: a leak post means the victim refused to pay, so leak sites measure intrusions, not ransom revenue.

Q4. What is unique about their TTPs?

Each successful group has industrialised one stage of the kill chain: Play scales initial access, Chaos skips it through social engineering, and SETTRA weaponises the leak itself.

Tactic	Play (most prolific)	Chaos (most damaging)	SETTRA (fastest riser)
Initial access	Mass exploitation of edge devices: Check Point gateway (CVE-2026-50751), Cisco FMC (CVE-2026-20131), ScreenConnect (CVE-2024-1708); plus infostealer / broker credentials	Vishing over Microsoft Teams: fake "IT support" talks staff into Quick Assist or an RMM tool	Valid accounts: 31.8% of victim domains appear in infostealer logs
Execution & persistence	Encoded PowerShell, scheduled tasks	PowerShell backdoor; AnyDesk / DWAgent / RemSupp; registry keys disguised as "Realtek HD Audio"	Not yet publicly analysed

Tactic	Play (most prolific)	Chaos (most damaging)	SETTRA (fastest riser)
Exfiltration	Rclone to cloud storage before encryption	Data stolen before encryption; average 458 GB per victim	141 GB median, up to 3.2 TB (Doosan)
Speed	Access to encryption in under 48 hours	Under 17 hours from the Teams call to ransomware	~20 days from compromise to post (deliberate staging)
Extortion	Countdown of exactly ~4 days, then full dump (87% "PUBLISHED FULL")	Teaser leaks ("we are publishing 5%"), 48–72 hour ultimatums, "exposure" essays	Long-form "investigative exposé" on each victim, plus revenue on every post

What makes this work:

- **Speed beats detection.** Hours-to-days dwell times leave little room for a SOC to respond, especially at small firms without one.
- **Living off the land.** Legitimate tools (Quick Assist, AnyDesk, Rclone, PowerShell) blend in with normal IT activity.
- **The human is the vulnerability.** Chaos bypasses MFA by having an employee open the door.
- **Psychological pressure is engineered.** Fixed countdowns, partial leaks and public essays shame victims in front of customers and regulators.

The other two groups add their own twists: Anubis ships a wiper mode that destroys files so that even paying cannot restore them, and DireWolf runs a Go-based ChaCha20 encryptor after deleting logs and backups.

Q5. Do actors re-brand or recycle old leaks to inflate their reputation?

Yes, it is common enough that analysts treat every leak-site claim as unverified until proven. A long victim list attracts affiliates and frightens new targets, so groups have reasons to pad it.

Known patterns:

- **Fabricated claims.** 0APT listed over 200 "victims" in its first week (late Jan 2026). Researchers found invented company names and fake downloads made of random data.

- **Recycled breaches.** Babuk2 extorted organisations using data from earlier RansomHub, LockBit and FunkSec leaks. After its 2024 takedown, LockBit claimed the US Federal Reserve; the data was really from Evolve Bank.
- **Re-branding and affiliate disputes.** Hunters International victims reappeared under World Leaks. Change Healthcare was claimed by ALPHV and then RansomHub after an affiliate was cheated.

Evidence in our own data:

- **Anubis – Singing River Health System (posted 3 Jun 2026).** Rhysida hit Singing River in Aug–Sep 2023. The data types in the Anubis post (SSNs, driver's licences, bank accounts, insurance, diagnoses) mirror the 2023 breach notice. This looks like recycled or re-sold data rather than a new intrusion.
- **Anubis – "Langley Twigg Law | Part 2".** Re-posting a second instalment keeps an old victim on the front page.
- **Vague, sensational descriptions.** 19 of 65 Anubis posts name no data type at all ("A data breach at a company full of smiling patients"). That style is marketing, not evidence.
- **Chaos's lineage.** Chaos appeared in 2025 after the BlackSuit takedown and is widely seen as a re-brand of BlackSuit/Royal operators; re-branding keeps the skills while shedding the "burnt" name.
- **SETTRA's origin.** Researchers say SETTRA may be "a rebranded affiliate cluster"; it had no history before June 2026 yet posted 64 victims in 100 days.

We found **no victim domain listed by two of our five groups**, so within this sample double-claiming was not visible.

Q6. Does company size or revenue change the risk?

Yes, but not the way people expect: small and mid-sized firms are hit most often, while large firms lose far more data per attack. SETTRA is the only site that prints revenue on every post, so we use its 64 victims.

Victim revenue	Victims	Share	Median data claimed
Under $10M	24	38%	65 GB
$10M – $50M	22	34%	147 GB
$50M – $100M	3	5%	439 GB
$100M – $1B	13	20%	260 GB

Victim revenue	Victims	Share	Median data claimed
Over $1B	2	3%	2,285 GB

The median victim earns about $19M a year, and 72% earn under $50M. Revenue and leak size are clearly linked (r = 0.58 on a log scale): Doosan ($13B) lost a claimed 3.2 TB, a $5M law firm 1 GB.

Why mid-sized firms carry the most risk:

- **Weaker defences.** They run the same exposed VPNs and remote tools as large firms but rarely have a 24/7 SOC, EDR or a patching team.
- **Big enough to pay.** A $10–50M firm can find a six-figure ransom; a corner shop cannot, and a Fortune 500 attracts law enforcement.
- **Opportunistic targeting.** Mass scanning and infostealer logs find whoever is vulnerable, not whoever is biggest.

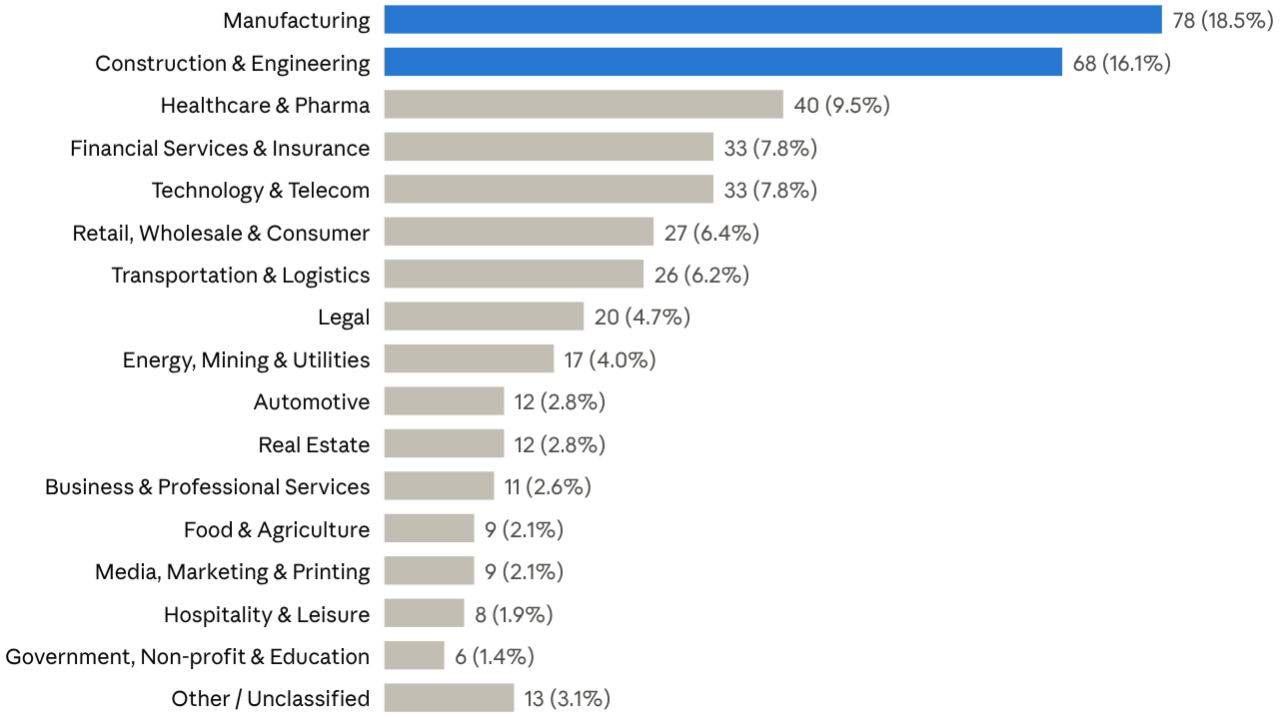
The other sites agree. Play's list is almost all regional SMBs (country clubs, title companies, small manufacturers). Anubis and Chaos mix in large brands (Coca-Cola's Fairlife, AkzoNobel, Horizon Media), where the reputational lever is greatest. Large firms are not safer; they are fewer, and when hit, the damage is larger.

Q7. Which industries are most prone to ransomware, and why?

Manufacturing (78 victims, 18%) and construction & engineering (68, 16%) lead, followed by healthcare (40, 9%). Each group has its own favourite: Play is construction-heavy (42 of 167), Chaos is manufacturing-heavy (21 of 83), and Anubis is healthcare-heavy (16 of 65, 25%).

Manufacturing and construction account for a third of all victims

Victims by industry, all five groups, Jan–Sep 2026 (n = 422; top two = 35%)



Combined leak-site data, 422 victims · industries for Play and SETTRA classified by us from company names

Why these industries:

- **Manufacturing:** downtime is instantly expensive (a stopped line loses money every hour), so pressure to pay is high. Old OT and ERP systems are hard to patch, and IT budgets are thin.
- **Construction & engineering:** many small firms, many subcontractors with remote access, and project deadlines with penalty clauses. Their drawings, bids and contracts are valuable to competitors.
- **Healthcare:** patient data is the most sensitive data there is (HIPAA fines, lawsuits), and hospitals cannot tolerate outages because lives are at stake.
- **Financial, legal and accounting firms (53 combined):** small offices that hold huge amounts of *their clients'* confidential data, which multiplies the extortion pressure.
- **Technology & SaaS:** one breach exposes thousands of downstream customers (DireWolf's Cartrack, InfoFlo CRM, Aztec Software).

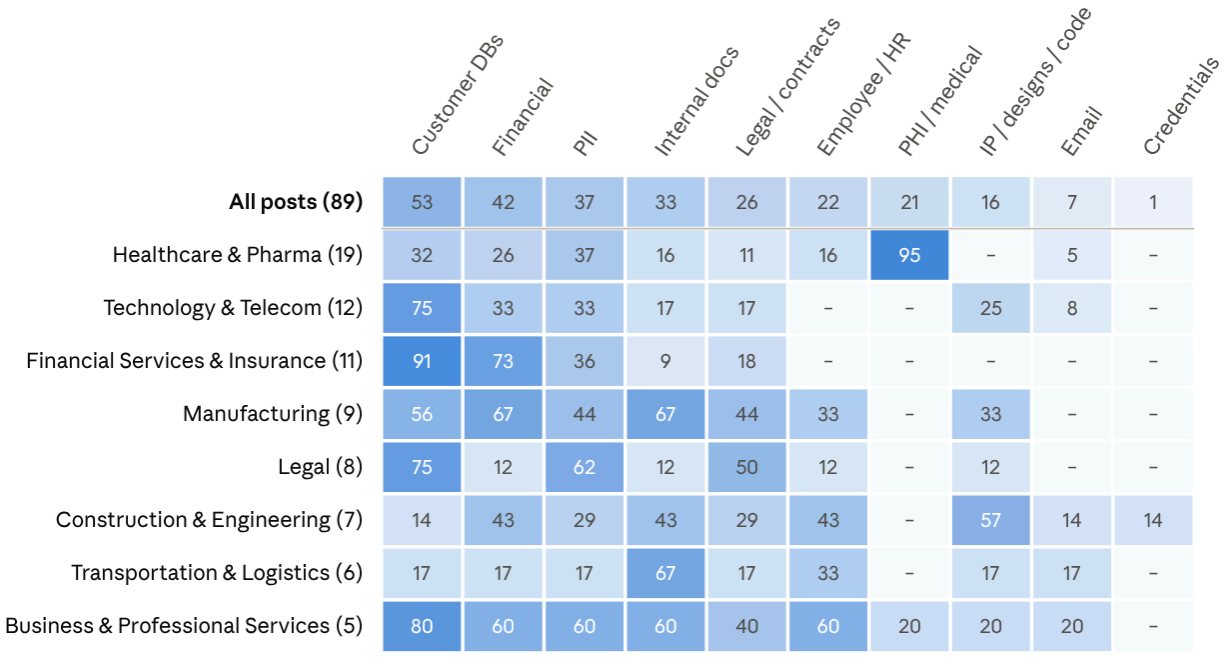
The common thread is **low tolerance for downtime plus high-value data plus under-funded security**.

Q8. What kinds of data do actors target, by industry?

Actors steal whatever makes the victim's customers, regulators and competitors care: customer databases (53% of posts), financial records (42%) and personal identifiers (37%) top the list. Only Anubis and DireWolf say what they took, so this breakdown uses their 89 posts that name a data type.

Each industry leaks the data it is trusted with

% of victim posts that list each data type, by industry (Anubis + DireWolf posts that name the data, n = 89)



Anubis 'Type of Data Stolen' + DireWolf 'leaked_data_types' fields, keyword-coded into 10 categories · industries with ≥ 5 coded posts

What each industry loses:

Industry	Signature data stolen	Example from the leak sites
Healthcare & Pharma	Medical records / PHI (95%), plus SSNs, insurance IDs, bank details	About Women Ob-Gyn: SSNs, passports, Medicare IDs, medical-record numbers
Financial Services & Insurance	Client databases (91%) and financial / tax records (73%)	Honeycomb Insurance: 79.6 million policy and claims documents
Technology & SaaS	Production customer databases (75%), source code	Cartrack: client bank & ID data, ~1 billion GPS events; Mighty Kingdom: source code

Industry	Signature data stolen	Example from the leak sites
Legal	Client PII (62%) and case / legal files (50%)	Langley Twigg: client passport scans; Abel Schillinger: patent drafts
Manufacturing	Financial records and internal documents (67% each), contracts, designs	Samkwang: data on Samsung and other Korean tech firms
Construction & Engineering	Designs and project data (57%), employee records	Envirogen: military-related project data; A J Taylor: drawings for hospitals and schools
Transportation & Logistics	Internal / operational documents (67%)	Adriatic Port Authority: safety plans and employee records

The logic is leverage. Personal and health data trigger notification laws, fines and lawsuits. Designs and source code threaten competitive advantage. Client databases let the actor pressure the victim's own customers, and can be re-sold for fraud even if no ransom is paid.

Q9. Three interesting insights

1. DireWolf quietly changed business model in August: from encrypting factories to stealing SaaS databases

DireWolf's first 16 posts (Jan–Jun) are classic ransomware victims: manufacturers, engineering firms and a Malaysian petroleum company, listed with document categories ("Financial Documents, Design Drawings"). Its 27 posts from August on look completely different. 22 of them are **database dumps with row counts** (Aztec Software: ~283.6 million MongoDB documents; Cartrack: ~1.28 billion rows), and almost every victim is an online platform: fintech wallets, e-prescribing, oncology EHR, HOA portals, game studios, a university.

- **Why it matters:** this is data-only extortion of cloud databases, with no encryption needed. One SaaS breach exposes every customer of that platform (TrainMe's leak contains ~24,500 SNCF employee emails).
- **The tell:** posts now carry "in-data evidence" and "100% verified line-by-line" claims, a sales pitch to buyers proving the data is real. Published TTP profiles of DireWolf (a Go encryptor) have not caught up with this shift.

2. Leak-site "popularity" metrics are fake: Play's view counter is a clock

Play shows a view count on every post, and older posts have more views. The fit is almost perfect: **r = 0.996 between a post's age and its views, about 153 extra views per day for every victim alike**. A January post sits at ~43,000 views, a September post at ~3,000, regardless of how famous the victim is (MyPillow is no higher than a small country club of the same week).

- **Meaning:** the counter is driven by crawlers (including researchers like us) or simply inflated, not by human interest. SETTRA shows the same problem in reverse: most posts show 0 views, but one (Canopy Brands) shows 525,849.
- **Other signs of a factory:** the gap from listing to full leak is 4 days for 75% of Play posts; up to 9 victims are posted in one day; 87% end as "PUBLISHED FULL".
- **Lesson for CTI:** never use actor-controlled numbers (views, sizes, file counts) as evidence of impact without checking.

3. Actors research their victims with the same sales-intelligence tools as legitimate businesses

SETTRA prints revenue on every post, and **14 of its 64 victims (22%) show exactly $5,000,000**, the bottom bucket that commercial company databases use for "under $5M". Chaos goes further: its posts paste text that is formatted exactly like a ZoomInfo profile ("$738.9 Million | Gas Stations, Convenience & Liquor Stores Retail", "904.6 Million | Commercial & Residential Construction").

- **Meaning:** victims are priced, not just hacked. Revenue lookups set the ransom demand and decide who is worth the effort, which explains the $10–50M sweet spot in Q6.
- **Bonus finding on intelligence quality:** one 2026 threat report listed "Andorra" among Play's target countries. In our data that entry is Andorra Life, a US insurer. Automated CTI that parses victim names can turn a company into a country; analysts must check the raw data.

Q10. Lessons learnt, struggles and how we overcame them

The hardest part was not collecting the data but making five differently built leak sites comparable.

Struggle	How we overcame it
Five sites, five schemas: Play has no industry, SETTRA no country or industry, Chaos no post dates, DireWolf mixes document categories and row counts	Built one combined table with a common 17-industry taxonomy; classified Play and SETTRA victims by name and website; flagged Chaos as undated and left it out of time-based charts
Inconsistent formats: dates as 4/1/2026 vs 2026-01-04, sizes as "3,4 TB", "164GB", "N/AGB"	Parsed dates explicitly as day-first, normalised all sizes to GB in Python, and treated unparseable values as missing rather than zero
Countries hidden behind ".com" domains (SETTRA)	Used country-code domains and known HQs; kept 27 victims as "Unknown" instead of guessing US
Vague or boastful descriptions ("A data breach at a company full of smiling patients")	Coded data types only when a post named them; 19 Anubis posts were excluded from Q8
Accessing Tor leak sites safely	Scraped through Tor from an isolated environment and used tracker sites (ransomwatch, SOCRadar) to cross-check
Trusting criminal claims	Cross-checked headline victims against news and breach notices, which exposed the recycled Singing River data and the bot-driven view counters

Lessons learnt:

- **Treat every leak-site field as a claim, not a fact.** Sizes, revenues and views are set by the actor.
- **Normalise before you compare.** Most early "insights" came from schema differences, not real differences between groups.
- **A leak site is a list of non-payers.** Conclusions about "success" need ransom-payment data that leak sites never show.

Sources

Primary data: our scrapes of the Play, Chaos, Anubis, SETTRA and DireWolf leak sites (files play_victims_all_pages.csv, Chaos_Ransomware_Victims.xlsx, anubis_victims.csv, leaksite_victims.csv, direwolf.csv).

- Security Arsenal – Play ransomware: edge-device exploits (2026)
- BleepingComputer – Microsoft Teams vishing attacks lead to Chaos ransomware (Jul 2026)
- Proven Data – SETTRA ransomware profile
- Proven Data – Dire Wolf ransomware profile
- Trend Micro – Anubis: ransomware with built-in wiper
- The Hacker News – Chaos RaaS emerges after BlackSuit takedown
- Rankiteo – Five reasons the same victim is claimed twice
- SC World – 0APT accused of faking breaches
- Cybersecurity News – Babuk2 fake extortion with recycled data
- Breachsense – Singing River Health System breach (Rhysida, 2023)
- Reuters – Gang claims hack of Coca-Cola's Fairlife unit (Jul 2026)